

專案類型：企業網路設計與實作

平台：Cisco IOS / GNS3

安全框架：ISO 27001:2022

關鍵技術：DMVPN (mGRE, NHRP), IPsec

傳統問題：隨著分公司的增加，VPN配置的管理變得越來越困難。

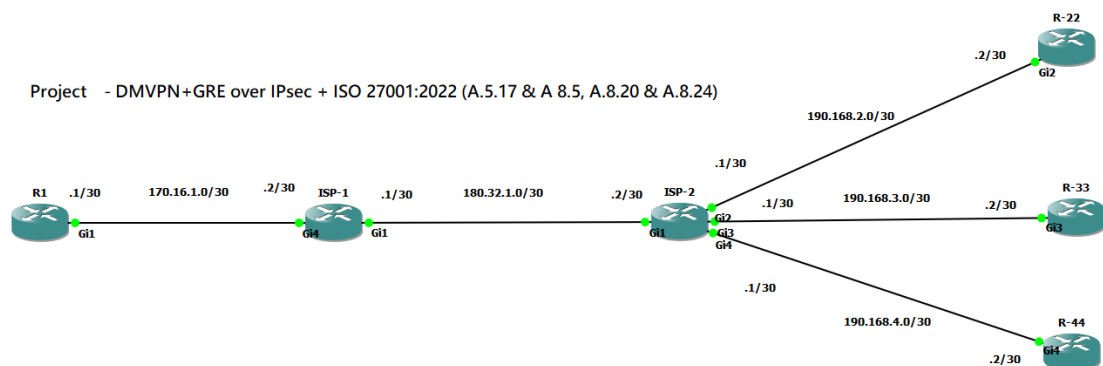
- **高可用性與擴充性 (Available & Scalability)**：企業擁有多個分支機構 (Branch)，傳統 Site-to-Site VPN 擴充困難 (Mesh 網狀拓撲需要手動建立無數隧道)，因此選用思科專有技術 **DMVPN** 達成動態、隨需 (On-demand) 的分支互聯。
- **安全性與法規遵循**：純 GRE 隧道缺乏加密能力 (明文傳輸)，為了保護敏感企業資料並符合 **ISO 27001:2022 A.5.17 & A 8.5, A.8.20 & A 8.24** 要求，必須疊加 **IPsec** 進行機密性保護。同時關閉路由器和交換器上未使用的協定及遺留功能會增加攻擊面。停用不必要的服務有助於防範網路攻擊

ISO 27001:2022

A 5.17 (Authentication information) & **A 8.5** (Secure authentication) : Never store, transmit, or display credentials in clear text. ("No Clear Text Rule ")

A.8.20 (Networks security) & **A.8.24** (Use of cryptography) : Use cryptography so sensitive data isn't exposed in clear text. (Data Storage / Transit)

Logical Topology



.IP Address Table

R1			
Interface	IP address	Subnet Mask	Description
G1	170.16.1.1	/30	Connect to ISP-1
G2	shut down		

G3	shut down		
G4	shut down		
tunnel 100	10.1.1.1	/24	tunnel mode to (gre) multipoint
ISP-2			
Interface	IP address	Subnet Mask	Description
G1	180.32.1.2	/30	Connect to ISP-1
G2	190.168.2.1	/30	Connect to R-22
G3	190.168.3.1	/30	Connect to R-33
G4	190.168.4.1	/30	Connect to R-44
R-22			
Interface	IP address	Subnet Mask	Description
G1	shut down		
G2	190.168.2.2	/30	Connect to G2
G3	shut down		
G4	shut down		
tunnel 122	10.1.1.2	/30	tunnel mode to (gre) multipoint

R1, Hub, ynamic mapping to registered Spoken devices (R-22,R-33,R-44)

```

R1#sh ip nhrp brief
*****
NOTE: Link-Local, No-socket and Incomplete entries are not displayed
*****
Legend: Type --> S - Static, D - Dynamic
Flags --> u - unique, r - registered e - temporary, c - claimed
a - authoritative, t - route
=====

Intf      NextHop Address      T/Flag      NBMA Address
Target Network
-----
Tu100     10.1.1.2             D/r         190.168.2.2
          10.1.1.2/32
Tu100     10.1.1.3             D/r         190.168.3.2
          10.1.1.3/32
Tu100     10.1.1.4             D/r         190.168.4.2
          10.1.1.4/32

```

R1 create Overlay tunnel to other tunnel by using nhrp and NMBA

```
R1#sh ip nhrp
10.1.1.2/32 via 10.1.1.2
  Tunnel100 created 00:27:53, expire 00:07:57
  Type: dynamic, Flags: registered nhop
  NBMA address: 190.168.2.2
10.1.1.3/32 via 10.1.1.3
  Tunnel100 created 00:16:14, expire 00:07:00
  Type: dynamic, Flags: registered nhop
  NBMA address: 190.168.3.2
10.1.1.4/32 via 10.1.1.4
  Tunnel100 created 00:16:13, expire 00:07:01
  Type: dynamic, Flags: registered nhop
  NBMA address: 190.168.4.2
```

R-22, Spoken, create Static mapping to Hub, and create Dynamic Mapping other Spoken, R-33 & R-44

```
R-22#sh ip nhrp brief
*****
NOTE: Link-Local, No-socket and Incomplete entries are not displayed
*****
Legend: Type --> S - Static, D - Dynamic
        Flags --> u - unique, r - registered, e - temporary, c - claimed
        a - authoritative, t - route
=====
```

Intf	NextHop Address Target Network	T/Flag	NBMA Address
Tu122	10.1.1.1		170.16.1.1
	10.1.1.1/32	S/	
Tu122	10.1.1.3		190.168.3.2
	10.1.1.3/32	D/	
Tu122	10.1.1.4		190.168.4.2
	10.1.1.4/32	D/	

R1 use OVERLAY tracetoute to R-33

```
R1#Traceroute 190.168.3.2
Type escape sequence to abort.
Tracing the route to 190.168.3.2
VRF info: (vrf in name/id, vrf out name/id)
  1 170.16.1.2 7 msec 1 msec 2 msec
  2 180.32.1.2 6 msec 4 msec 6 msec
  3 190.168.3.2 11 msec * *
R1#
R1#Traceroute 10.1.1.3
Type escape sequence to abort.
Tracing the route to 10.1.1.3
VRF info: (vrf in name/id, vrf out name/id)
  1 10.1.1.3 16 msec * 6 msec
```

R1 - Tunnel 100 is applied IPsec , # pkts encrypt / decryptpt

```
interface Tunnel100
 ip address 10.1.1.1 255.255.255.0
 no ip redirects
 ip mtu 1400
 ip nhrp authentication 100
 ip nhrp network-id 100
 ip nhrp redirect
 ip tcp adjust-mss 1360
 tunnel source 170.16.1.1
 tunnel mode gre multipoint
 tunnel key 100
 tunnel protection ipsec profile NY-IPSEC-PROFILE
```



```

R1#show crypto ipsec sa

interface: Tunnel100
  Crypto map tag: Tunnel100-head-0, local addr 170.16.1.1

  protected vrf: (none)
  local ident (addr/mask/prot/port): (170.16.1.1/255.255.255.255/47/0)
  remote ident (addr/mask/prot/port): (190.168.4.2/255.255.255.255/47/0)
  current_peer 190.168.4.2 port 500
    PERMIT, flags={origin is acl.}
    #pkts encaps: 48, #pkts encrypt: 48, #pkts digest: 48
    #pkts decaps: 47, #pkts decrypt: 47, #pkts verify: 47
    #pkts compressed: 0, #pkts decompressed: 0
    #pkts not compressed: 0, #pkts compr. failed: 0
    #pkts not decompressed: 0, #pkts decompress failed: 0
    #send errors 0, #recv errors 0

  local crypto endpt.: 170.16.1.1, remote crypto endpt.: 190.168.4.2
  plaintext mtu 1458, path mtu 1500, ip mtu 1500, ip mtu idb (none)
  current outbound spi: 0x6F9BBCCA(1872477386)
  PFS (Y/N): N, DH group: none

```

Comply with ISO 27001:2022 A.8.20 – Network Security - remove non-use services

```

R1#sh ip int br

```

Interface	IP-Address	OK?	Method	Status	Protocol
GigabitEthernet1	170.16.1.1	YES	NVRAM	up	up
GigabitEthernet2	unassigned	YES	NVRAM	administratively down	down
GigabitEthernet3	unassigned	YES	NVRAM	administratively down	down
GigabitEthernet4	unassigned	YES	NVRAM	administratively down	down
Tunnel100	10.1.1.1	YES	NVRAM	up	up

Turn off non-used ports

```

!
no ip forward-protocol nd
no ip http server
no ip http secure-server
!

```

```

no aaa new-model
no ip source-route

```

Comply with ISO 27001:2022 A 5.17, A 8.5, A8.24 – "No Clear Text Rule " & Data ncryption

```
service timestamps debug datetime msec
service timestamps log datetime msec
service password-encryption
platform qfp utilization monitor load 80
no platform punt-keepalive disable-kernel-core
platform console serial
```

```
!
crypto ikev2 keyring NY-RING
  peer NYC
    address 0.0.0.0 0.0.0.0
    pre-shared-key 6 ZKiCQV\^WTcgSZNJUOS\^AgaAYZ]]F[B
```

```
line vty 0 4
  exec-timeout 5 0
  login
  transport input ssh
line vty 5 15
  exec-timeout 5 0
  login
  transport input ssh
```

Risk Assessment

Risk / Issue	Mitigation in your lab?	Status
WAN traffic exposed in clear text	GRE protected with IPsec	 Implemented
Unnecessary network services	Disabled unused services	 Implemented
Clear-text authentication information	Secure authentication approach	 Implemented
Unauthorized router access	Not-In-this Lab	Not-In-this Lab
Weak passwords	Not-In-this Lab	Not-In-this Lab